WHAT IS INSIDE

An AI agent asks. A person decides. Does that hold up?

I built a small open-source approval gateway for MCP tool calls and tried to break it, three times over. I changed things after approval, hid characters in names, replayed requests, pushed secrets through, and let a real client, Claude Code, walk the whole path.

- 210 scripted checks, 81 documented use cases, every one with what I did and what happened
- Six problems found and fixed, and 22 limits written down instead of hidden
- The permit and the receipt: what a downstream tool really gets
- Government, school, business, IT and plant tools, tried the same way
- A checklist of 13 questions to put to any approval step you buy or build

It is written for the people who have to say yes to agents in their company: security leads, IAM and PAM teams, auditors and the curious.

Everything ran on made-up tools and made-up data. The results show what this gateway did on these cases, on my own machines. They do not prove it secure.



Roshan Trivedi
IAM, PAM and agentic AI security. Fourteen years in identity and privileged access. Bengaluru, India.

FIND ME
roshantrivedi.co.in
linkedin.com/in/roshan-trivedi-ciam-49413a54
roshantrivedi.co.in/mcp-lab-portal/

HumanGate MCP Approval Lab ROSHAN TRIVEDI

MCP APPROVAL LAB

Can a person stay in control of an AI agent?

Three rounds of trying to break a human approval gateway for MCP tool calls. What held, what did not, and what an organisation can take from it.



210 SCRIPTED CHECKS

81 USE CASES

22 LIMITS STATED

WRITTEN BY
Roshan Trivedi
IAM, PAM and agentic AI security